CIS LINUX AUDIT · VERSIÓN 1.0.0

Arquitectura del Proyecto

Flujo de datos, componentes, solo lectura, fail-closed, confianza, recolectores, políticas y métricas.

Versión 1.0.0 | Fecha 2026-11-10 | Versión operativa | Auditoría de solo lectura

Contenido

1. Visión general
2. Estructura del proyecto
3. Componentes de software
4. Solo lectura
5. Fail-closed
6. Confianza y privilegios
7. SHA-256 de los collectors
8. Deep filesystem
9. Políticas
10. Exclusiones y omisiones
11. Métricas

1. Visión general

CIS Linux Audit transforma fuentes canónicas (líneas base Excel y CIS Benchmarks oficiales) y evidencia técnica de solo lectura en resultados reproducibles. El flujo es lineal y cada etapa deja un artefacto verificable:

Los reportes se generan siempre desde el JSON normalizado de la ejecución: pueden regenerarse en cualquier momento sin volver a conectarse a los servidores.

2. Estructura del proyecto

```
cis-linux-audit/
├── VERSION                 1.0.0
├── LEEME.txt               punto de entrada e índice de docs/
├── ansible.cfg             SSH por llave, BatchMode, sin become, sin facts
├── requirements.txt        dependencias Python del controlador
├── inventory/              hosts.yml.example (hosts.yml lo crea el operador)
├── playbooks/              precheck.yml, recolectar.yml (solo ansible.builtin.raw),
group_vars/
├── plugins/filter/         cis_redaccion.py (redacción en el controlador antes de persistir)
├── collectors/             principal-1.8.0/ y fs-1.1.0/ (script, sudoers y SHA-256)
├── templates/              plantillas sudoers de los recolectores
├── config/                 audit.yml, listas_aprobadas.yml, mapeo_parte1.yml,
revisiones_mapeo.yml, prerrequisitos_parte1.yml
├── data/                   alcance/, cis_catalog/, exclusiones/ (generados por "preparar")
├── input/                  baseline/ (Excel P1/P2, files/p1/ banners) y cis/ (PDF oficiales)
├── src/                    auditar.py (CLI) y paquete cis_audit/
├── docs/                   documentación (PDF)
└── results/                ejecuciones (vacío en la entrega)
```

Directorio	Por qué existe
playbooks/ y plugins/	Ansible ejecuta el precheck y la recolección con raw; el filtro redacta secretos en el controlador.
collectors/	Entregables que Infraestructura instala (script + sudoers + SHA-256). Se regeneran con generar-recolector-*.
templates/	Plantillas sudoers usadas por el generador: su contenido forma parte del SHA-256 del sudoers.
data/	Datos derivados de las fuentes canónicas, con SHA-256 de origen; verificados antes de cada ejecución.
build/	Se crea en tiempo de ejecución por 'plan' (scripts de dry-run); no forma parte de la entrega.
src/	Código Python (sin dependencias de red ni servicios).

3. Componentes de software

Módulo	Responsabilidad
src/auditar.py	CLI: preparar, plan, precheck, ejecutar, reportes, informe-proveedor, reevaluar, generar-recolector-*, matriz-controles, demo.
cis_audit/cis_catalog.py	Extrae los controles de los PDF CIS (pdftotext) con caché por SHA-256 del PDF.
cis_audit/linea_base_p2.py, excel_baseline.py, mapeo.py, exclusiones.py	Matriz de alcance de la Parte 2 y clasificación de sus exclusiones.
cis_audit/parte1.py, excepciones_p1.py	Matriz de la Parte 1, prerrequisitos y parser exacto de las exclusiones P1.
motor/comandos*.py, seleccion.py, plan.py	Catálogo de comandos read-only y generación del script recolector por benchmark.
motor/privilegiado.py, filesystem.py	Generación y verificación estática de los recolectores principal y FS.
motor/operacion.py	Validación de inventario y --limit, interpretación del precheck y gate de confianza.
motor/recolector.py, redaccion.py	Parser del formato delimitado de evidencia y redacción de secretos.
motor/controles.py, controles_p1.py, root_path.py, auditd_reglas.py	Evaluadores por control según el Audit CIS.
motor/evaluacion.py, evaluacion_p1.py, prerrequisitos_eval.py	Evaluación por host, persistencia de evidencia por control, P1, PRE.
motor/resultado_final.py, porcentaje.py, partes.py	Capa de resultado final y los cuatro indicadores.
reportes/html.py, excel.py	Reportes HTML y XLSX desde el mismo JSON normalizado.
reportes/proveedor.py	Informe consolidado de remediación para el proveedor (HTML + PDF), con varios servidores.
motor/simulacion*.py	Evidencia sintética para 'demo' (verificación de la instalación sin conexión).

4. Solo lectura

- Ansible usa exclusivamente `ansible.builtin.raw`: no copia módulos ni archivos al servidor y no recolecta facts.
- El script recolector viaja en base64 y se ejecuta con `bash -s`; no se escribe en el disco del servidor.
- Cada comando del catálogo se valida antes de cada ejecución: sin redirecciones a archivo, sin instalación de paquetes, sin cambios de servicios, GRUB, auditd, crypto-policies, firewall, kernel ni usuarios; refresco de repositorios deshabilitado.

- Prohibidos en cualquier modalidad: aide --init/--check, augenrules, auditctl -e/-R, grub2-mkconfig, authselect apply, systemctl daemon-reload, journalctl --vacuum, logrotate -f y procedimientos de Remediation.
- logrotate solo con `-d`, rsyslogd solo con `-N1`, rpm -V solo con `--noscripts`.
- El PATH de root (5.4.2.5) se analiza estáticamente: nunca se ejecuta el perfil de root.

5. Fail-closed

Situación	Resultado
Evidencia ausente, incompleta o ilegible	ERROR DE AUDITORÍA (nunca CUMPLE ni NO CUMPLE)
Recolector no confiable	No se ejecuta; gate BLOQUEADO; ningún control CIS
Fallo del filtro de redacción	Se descarta toda la salida privilegiada (RECOLECCION_PRIVILEGIADA_FALLIDA)
Recorrido de filesystem truncado	Nunca CUMPLE
Celda de exclusión con formato inválido	'preparar' se detiene
data/ distinto del Excel vigente	plan/precheck/ejecutar se detienen (rc 6)
Exclusión que no cubre todos los hallazgos	Resultado final NO CUMPLE con los hallazgos no cubiertos
Valor efectivo no determinable sin ejecutar código	REQUIERE VALIDACIÓN MANUAL

6. Confianza y privilegios

La confianza en la evidencia privilegiada se basa en que el servidor ejecuta **exactamente** el script revisado:

- Ruta fija `/usr/local/libexec/cis-audit/cis-audit-collect`, root:root 0755, sin setuid, sin ACL de escritura, directorios padre y del PATH de root y no escribibles.
- Regla sudoers con `sha256:<digest>`: si el archivo cambia, sudo deja de autorizarlo.
- El precheck recalcula el SHA-256, revisa metadatos y ACL reales (getfacl) y consulta `sudo -n -l <ruta>`; la recolección vuelve a comprobar el SHA-256 inmediatamente antes de ejecutar.
- El script no acepta argumentos ni stdin, reconstruye el entorno (`env -i`), usa PATH fijo, `umask 0077` y `bash -p`.
- La cuenta srvinnops no tiene sudo general; la regla NOPASSWD del recolector se reconoce como instrumentación de auditoría solo si el sudoers coincide byte a byte con el SHA-256 aprobado.

7. SHA-256 de los collectors

Artefacto	Versión	SHA-256
cis-audit-collect (principal)	1.8.0	f4d5a4a7166e52e906329b7e374db6877e3599182ebe299c58648715d01cf257
/etc/sudoers.d/cis_audit (bytes exactos)	1.8.0	3c7af32ec498d5e5606c00ad5bec01631ca938454b8a6cfe8ad2ce795ac4f7e9
cis-audit-collect-fs	1.1.0	9b3fa54edb054ea1d4ad54022257bd9fec0ccb5bc73036a477b9f38ec0f6b91c
/etc/sudoers.d/cis_audit_fs (bytes exactos)	1.1.0	f406f580f372a3b13e93e6d4f0feef3b5fd5d94a88f339e48cbe11795569b122

Los valores aprobados están en `config/audit.yml`. Los generadores son deterministas: el mismo código produce el mismo SHA-256, y `generar-recolector-*` devuelve rc 4 si lo generado no coincide con la configuración.

8. Deep filesystem

- Recolector independiente y temporal (cis-audit-collect-fs), con su propia regla sudoers.
- Solo con `--filesystem-profundo` explícito y el recolector FS CONFIABLE; nunca implícito.
- Selección de montajes y exclusiones literales del Audit CIS; -xdev, nice/ionice y timeout.
- Salida con formato cerrado y marca de completitud por categoría; un recorrido truncado nunca produce CUMPLE.
- Sin la evidencia FS, los controles afectados quedan REQUIERE VALIDACIÓN MANUAL (PENDIENTE_AUDITORIA_PROFUNDA).

9. Políticas

Política (config/listas_aprobadas.yml)	Controles	Uso
metodo_logging: rsyslog	6.2.1.4, 6.2.2.x, 6.2.3.x	Aplicabilidad según la nota de cada Benchmark (fuente única).
rsyslog_reglas_aprobadas (7 reglas)	6.2.3.5	Comparación semántica selector + destino; además rsyslogd -N1 válido.
logrotate_rsyslog_politica	6.2.3.8	Cada archivo que rsyslog escribe cubierto con las directivas; logrotate -d sin errores.
ipv6_politica	3.1.1	IPv6 no requerido: estado aprobado deshabilitado.
pwquality_complejidad_aprobada	5.3.3.2.3	Créditos d/u/l/o = -1.
repositorios, claves_gpg, suid_sgid	1.2.1.x, 7.1.13	Listas aprobadas; vacías → REQUIERE EVIDENCIA ORGANIZACIONAL.
destinos_log	condición de exclusión P2 (SIEM)	Destinos centrales autorizados; solo informa el estado de la condición.

Banners: comparación SIMILITUD_TEXTUAL (umbral 0,95) contra `Message_Day` y `login_banner`, ignorando marco decorativo de '*', relleno, CRLF/LF y líneas vacías (`config/audit.yml → banners_*`). El SHA-256 del archivo no es condición de cumplimiento.

10. Exclusiones y omisiones

- Capa posterior a la evaluación técnica: `resultado_cis` nunca se modifica; se calcula `resultado_final`.
- P1: solo la columna 'Exclusiones de Infraestructura' del Excel P1 → `data/exclusiones/excepciones_p1.json` (origen LINEA_BASE_P1).
- P2: solo la columna 'EXCLUSIONES (Infraestructura Linux)' del Excel P2, y solo reglas sustitutivas verificadas.
- Una exclusión cubre únicamente los elementos que define (usuarios o componente); el resto sigue siendo hallazgo.
- CONTROL EXCLUIDO: actualizaciones, repositorios y llaves GPG (proceso formal independiente de parchado) y las filas P1 con exclusión de control completo (TIPO CONTROL_NO_APLICADO; p. ej. 3.4.3 y 3.4.4).
- Cada exclusión definida se valida contra la configuración real del servidor (APLICADA / NO APLICADA / NO VERIFICADA); las de usuarios, usuario por usuario. Módulo `motor/validacion_exclusiones.py`.

11. Métricas

Indicador	Fórmula	Base
Cumplimiento CIS técnico	CUMPLE / (CUMPLE + NO CUMPLE + CUMPLE PARCIALMENTE) × 100	resultado_cis
Cobertura técnica CIS	(CUMPLE + NO CUMPLE + CUMPLE PARCIALMENTE) / filas YES × 100	resultado_cis
Cumplimiento final de línea base	CUMPLE / (CUMPLE + NO CUMPLE + CUMPLE PARCIALMENTE) × 100 (CONTROL EXCLUIDO fuera)	resultado_final
Cobertura de validación	filas concluidas / filas YES × 100	resultado_final

Unidad: fila del Excel con propuesta YES, por host. Los cuatro indicadores nunca mezclan numeradores ni denominadores. Detalle: Modelo de Resultados y Cumplimiento.